

Security+ 3.1 · Cloud Infrastructures

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 3.1 — Cloud Infrastructures (9:56)

· [Vídeo no YouTube ↗](#)

Resumo da Aula: Nuvem: IaaS (EC2 — tu cuida do SO pra cima); PaaS (heroku/AWS Beanstalk — plataforma pronta); SaaS (Gmail — tudo pronto). Serverless/FaaS (Lambda: código sobe na chamada, paga por execução). IaC (Infrastructure as Code — Terraform, CloudFormation — infra VERSÃO-EDITÁVEL). Defesa: IAM, SG (security group), VPC.

Highlights que a prova cobra

- IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider
- Serverless (Lambda): sem servidor — paga execução
- IaC (Terraform): infra como código — versionada audível

Dicas de prova & Cenários Típicos

- 'cloud model where user manages the OS and above' = IaaS
- "runs code without managing servers" = serverless/FaaS

Cenário clássico de exame: Cenário: 'empresa aluga máquinas virtuais e gerencia o sistema operacional' — IaaS.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 3.1)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Cloud Infrastructures) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Modelos de Responsabilidade Compartilhada na Nuvem:**
 - **IaaS (Infrastructure as a Service):** provedor cuida da infraestrutura física/hipervisor; cliente cuida de SO, patches, middleware, rede e dados.
 - **PaaS (Platform as a Service):** provedor cuida do hardware, SO e runtime; cliente cuida do código da aplicação e dos dados.
 - **SaaS (Software as a Service):** provedor gerencia tudo; cliente é responsável apenas pelas configurações de acesso e segurança dos próprios dados.
- **Segmentação de Rede e Segurança Perimetral:**
 - **DMZ (Demilitarized Zone):** sub-rede perimetral intermediária para servidores públicos (web, mail), isolada da rede corporativa interna por firewalls.
 - **VLANs (Virtual LANs):** isolamento lógico de tráfego na camada 2 para separar departamentos sensíveis (ex: finanças, RH, visitantes).
 - **SASE (Secure Access Service Edge):** convergência de SD-WAN e serviços de segurança em nuvem (CASB, FWaaS, ZTNA) entregues próximos ao usuário.
- **Resiliência e Tolerância a Falhas de Armazenamento:**
 - **RAID 0:** striping sem tolerância a falhas (foco exclusivo em velocidade; perda de 1 disco destrói tudo).
 - **RAID 1:** espelhamento (tolera perda de 1 disco; consome 50% do espaço total).
 - **RAID 5:** paridade distribuída (mínimo 3 discos; tolera falha de 1 disco).
 - **RAID 6:** dupla paridade (mínimo 4 discos; tolera falha simultânea de até 2 discos).
 - **RAID 10 (1+0):** combinação de espelhamento e striping (alta performance e redundância).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- RAID NÃO substitui Backup. Se um arquivo for corrompido, excluído ou criptografado por ransomware, o RAID replica o dado corrompido instantaneamente nos discos espelhados.
- Na nuvem pública, a responsabilidade sobre a classificação e sigilo dos DADOS é SEMPRE do cliente em qualquer modelo (IaaS, PaaS ou SaaS).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Você aluga só a máquina virtual e gerencia o SO e tudo acima. Que modelo é?

- A)** SaaS
- B)** PaaS
- C)** IaaS
- D)** On-premises

2. Gmail, Office 365 e Salesforce são exemplos de qual modelo?

- A)** IaaS
- B)** PaaS
- C)** SaaS
- D)** FaaS

3. Qual modelo de serviço de nuvem oferece maior controle sobre a infraestrutura, incluindo sistema operacional e middleware?

- A)** SaaS
- B)** PaaS
- C)** IaaS
- D)** FaaS

4. Qual serviço AWS permite executar código sem provisionar servidores?

- A)** EC2
- B)** ECS
- C)** Lambda
- D)** Elastic Beanstalk

5. No modelo de RESPONSABILIDADE COMPARTILHADA, quem cuida da segurança FÍSICA do datacenter?

- A)** O cliente
- B)** O provedor de nuvem
- C)** Os dois igualmente
- D)** Um auditor externo

6. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'Serverless (Lambda): sem servidor — paga execução'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Serverless (Lambda): sem servidor — paga execução...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'IaC (Terraform): infra como código — versionada audível'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: IaC (Terraform): infra como código — versionada audível...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'cloud model where user manages the OS and above' = IaaS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'cloud model where user manages the OS and above' = IaaS...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Cloud Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'runs code without managing servers' = serverless/FaaS. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'runs code without managing servers' = serverless/FaaS...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) C — IaaS.

✓ **Por que está certa:** IaaS (Infra as a Service) = provedor dá a infra (VM, rede, storage) e você cuida do SO pra cima. Ex: EC2. PaaS entrega a plataforma pronta; SaaS entrega o app pronto (ex: Gmail).

✗ **Por que as outras estão erradas:**

- *SaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *PaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *On-premises*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) C — SaaS.

✓ **Por que está certa:** SaaS (Software as a Service): você só usa o app pronto pelo navegador, sem gerenciar nada por baixo. IaaS/PaaS exigem mais gestão sua.

✗ **Por que as outras estão erradas:**

- *IaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *PaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *FaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) C — IaaS.

✓ **Por que está certa:** IaaS provê infraestrutura virtualizada (servidores, armazenamento, rede) com controle total sobre OS e middleware.

✗ **Por que as outras estão erradas:**

- *SaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *PaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *FaaS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) C — Lambda.

✓ **Por que está certa:** Lambda é serverless: executa código em resposta a eventos sem gerenciar infraestrutura.

✗ **Por que as outras estão erradas:**

- *EC2*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *ECS*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Elastic Beanstalk*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

5) B — O provedor de nuvem.

✓ **Por que está certa:** O provedor cuida da segurança DA nuvem (hardware, datacenter, rede física). O cliente cuida da segurança NA nuvem (seus dados, acessos/IAM, configs). Config errada = culpa do cliente.

✗ **Por que as outras estão erradas:**

- *O cliente:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Os dois igualmente:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Um auditor externo:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

6) B — Implementar a solução correspondente: IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): IaaS: tu cuida do SO. PaaS: só tua aplicação. SaaS: tudo do provider.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Serverless (Lambda): sem servidor — paga execução....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): Serverless (Lambda): sem servidor — paga execução.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: IaC (Terraform): infra como código — versionada audível....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): IaC (Terraform): infra como código — versionada audível.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'cloud model where user manages the OS and above' = IaaS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): 'cloud model where user manages the OS and above' = IaaS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: 'runs code without managing servers' = serverless/FaaS....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Cloud Infrastructures): 'runs code without managing servers' = serverless/FaaS.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

